

Zenaian Privacy & Compliance Policy Decisions

Final locked policy specification

Final pre-implementation version 1.0 | August 14, 2026 | Repository snapshot d9137c605755

Final pre-implementation compliance specification. Operator/CPO placeholders remain for manual completion. Re-check Korean law in force on the actual launch date before publication.

1. Policy status

This document records decisions that public wording and code must implement consistently. It is not a substitute for the public Privacy Policy or Terms.

Core philosophy

Minimize collection and retention first. Use PIPA as the legal baseline, preserve only data needed to provide/secure the service or required by law, make deletion automated, and avoid architectural changes that do not materially improve privacy.

2. Locked decisions

Topic	Decision
Jurisdictional baseline	PIPA-first. GDPR principles are a voluntary design cross-check; Zenaian does not build an EU-specific compliance layer absent actual EU targeting/monitoring.
Minimum age	19+. Signup/Terms require representation that the user is at least 19. Do not collect date of birth unless a future compliance need requires it.
Question-content retention	No persistent screenshot, prompt/instruction, answer or question history. Content is held only for request execution and very short result polling.
Sensitive personal data	Intentional submission of identifiable sensitive personal information is prohibited. A clear pre-capture warning is required. Accidental submission remains transient.
xAI	ZDR is active and mandatory. Production server verifies x-zero-data-retention:true and fails closed if not confirmed. store:false remains but is not treated as the ZDR control.
Analytics	No third-party analytics, behavioral analytics, advertising pixels, cross-site profiling or sale of personal information.
Operational retention	Per-analysis accounting 30d; usage summaries 90d after period; checkout failures 7d/consumed 30d; provider events 30d; terminal membership operational copy <=90d; live user-facing payment history <=12 months; privacy request audit 1y.
Statutory retention	Korean E-Commerce Act records only: advertising 6mo; contract/withdrawal 5y; payment/supply 5y; complaints/disputes 3y. Personal statutory records live in a segregated legal-retention schema and are automatically destroyed at expiry.
Account deletion	Immediate service block and loss of remaining access/allowance. Cancel in-flight analyses, revoke extension sessions, request Whop future-renewal cancellation, archive legally required minimum, delete operational records, then delete Clerk user. Normal target: deletable active-system data completed within 24h, excluding provider outages, statutory retention and rolling recovery copies.

Topic	Decision
Deletion confirmation	Require explicit checkboxes acknowledging loss of access/unused allowance, subscription renewal cancellation, statutory retention exception and irreversibility, plus typed DELETE or equivalent high-friction confirmation.
Export	Authenticated human-readable privacy page + downloadable JSON. Do not export secrets/tokens or data Zenaian never stores.
Privacy contact	privacy@zenaian.com via Google Workspace. Product self-service remains primary.
Render logging	Only operationally necessary safe logs; native Render retention only; no third-party log warehouse at launch.
Whop metadata	Before production, send no Zenaian user-identifying custom checkout metadata. Omit clerk_user_id, checkout_intent_id and sneaksolve_plan metadata on new checkout unless a future provider requirement proves strictly necessary. Map via Whop checkout_configuration_id / provider IDs stored locally.
Whop tax	Product tax behavior is exclusive: applicable tax is added at checkout. Whop Collects and Remits is used where supported. Zenaian remains responsible for its seller/consumer-law obligations and for taxes outside Whop's supported scope.
Website hosting	Hosting.kr/Megazone is classified as a domestic Korean website-hosting contractor. Hosting is AWS-based; exact AWS region is not publicly named. Internal best-effort assumption: AWS Seoul. Disable Webalizer/AWStats/Analog and raw-log archiving by default; do not place Hosting.kr in the public overseas-transfer table on current evidence.
Google Workspace	Planned Business Standard; US covered-data-at-rest region; enforced 2SV; no personal forwarding; ordinary privacy email auto-delete at 365d; no Vault by default.
Obsolete Lemon Squeezy	Remove obsolete Lemon Squeezy schema/code before production after validating no required records exist. Raw webhook-body storage must not remain available as a dormant path.
Operator details	Use placeholders until business form/CPO/address/registration information is final.

3. Explicit legal-basis policy

The public Privacy Policy should state legal bases by article, not merely say “contract” or “legitimate interest.” Use the following article-level language, clearly marked as an English working translation of Korean law:

- Article 15(1)(4): “necessary to perform a contract concluded with the data subject, or to take measures requested by the data subject in the process of concluding a contract.” Use for account creation/authentication, deliberate AI analysis, quotas, subscription access and ordinary customer support.
- Article 15(1)(6): “necessary to achieve the controller’s legitimate interests and those interests clearly take precedence over the data subject’s rights,” with substantial relation and reasonable scope. Use narrowly for rate limiting, replay prevention, service security, fraud/abuse controls and short diagnostics.
- Article 15(1)(2): “where there is a special statutory provision, or processing is unavoidable to comply with a legal obligation.” Use for E-Commerce Act transaction/complaint retention and other concrete legal duties.
- Article 21: once data is unnecessary, destroy it without delay; if another law requires retention, store/manage it separately. This is the deletion/archive design rule.
- Article 23: Zenaian does not build a separate-consent sensitive-data workflow; instead, it prohibits intentional submission of identifiable sensitive personal information.
- Article 28-8(1)(3): overseas outsourcing/storage needed for contract performance is disclosed with the transfer information required by Article 28-8(2).

Do not use “consent” as a blanket basis for core service processing. If Zenaian later adds optional marketing, analytics or another processing purpose that actually needs consent, design that purpose separately.

4. Consumer purchase / withdrawal policy

The earlier wording “no refunds except where required” was directionally safe but too abstract for a Korean seller. The final terms expressly preserve Korean statutory withdrawal rights.

- Korean E-Commerce Act Article 17 generally provides a 7-day withdrawal period from the statutory starting point. [L4]
- The Act contains exceptions, including where provision of a service or digital content has begun, but those exceptions are conditioned by required consumer-facing measures; divisible services/content can retain withdrawal rights for the unprovided portion. [L4]
- If the service/content differs from the advertised or contractual description, Article 17(3) provides a separate window (within three months of supply or 30 days after discovery, as specified by the statute). [L4]
- For a valid withdrawal involving services/digital content, Article 18 requires refund within three business days from the relevant statutory event. [L4]
- Therefore the public terms may say Zenaian does not ordinarily offer discretionary prorated refunds, but must not imply that account deletion waives, replaces or extinguishes statutory withdrawal/refund rights.

Checkout implementation rule

Before relying on a digital-content/immediate-service withdrawal limitation, show the required clear checkout disclosure and implement any required measures. Have Korean counsel validate the final checkout configuration once the exact subscription/product classification is fixed.

5. Korea AI Basic Act transparency

This is a locked compliance item. The AI Basic Act has been in force since July 21, 2026. Article 31 requires advance notice when a product/service uses generative AI and requires AI-generated results to be marked. The Enforcement Decree permits notice in the product, contract/Terms, UI/device and permits human- or machine-readable output marking; a machine-readable-only method requires at least one human-readable notice. [L7][L8]

- Website/Terms/onboarding: state clearly that Zenaian uses xAI Grok generative AI to generate proposed answers.
- Advance notice: state in Website Terms, Chrome Web Store description and a static extension popup/settings line that Zenaian uses generative AI (xAI Grok). The AI Basic Act Enforcement Decree permits advance notice in Terms or on the user screen; no server-side acknowledgement record is required for this design.
- Result marking: use the Chrome action hover tooltip/title while the result state is displayed. Exact strings: single answer “AI-generated answer: B”; multiple answers “AI-generated answers: A, C”; inconclusive “AI-generated result: inconclusive”; processing “Zenaian - AI processing”. Keep the icon artwork itself unchanged.
- Regression tests must verify the generative-AI advance notice remains present and each result-state title uses the approved wording.

6. Whop minimization decision - code-impact review

The current repository sends `clerk_user_id` in checkout metadata. Whop's current API exposes `checkout_configuration_id` on both payments and memberships specifically for mapping provider records back to the checkout that created them. The final standard therefore removes the Clerk identifier from Whop metadata and uses the provider checkout ID stored in `billing_checkout_sessions` for mapping. [V12][V13]

- Create new Whop checkout with no Zenaian user-identifying custom metadata. Omit metadata entirely if supported, otherwise send an empty object. Do not send Clerk ID, local checkout-intent UUID or plan nickname because provider plan/checkout IDs already encode the needed provider relationship.
- After Whop returns `ch_...`, persist it locally against the authenticated Clerk user in `billing_checkout_sessions`.
- Incoming payment/membership events map by `checkout_configuration_id`; subsequent lifecycle events map by already-known provider membership/payment IDs.
- If a provider event does not contain enough mapping information, quarantine/reconcile through the provider API rather than adding broad personal metadata.
- Never store Whop `billing_address`, `card_last4` or other payment-method fields even if the API returns them.

7. Google Workspace setup standard

When `privacy@zenaian.com` is created, use this configuration unless a later requirement justifies a change:

- Business Standard; covered data-at-rest region = United States. Google currently offers US, Europe or No preference for supported editions. [V15]
- 2-Step Verification required for admin and privacy mailbox; prefer phishing-resistant methods. [V17]
- No forwarding to personal accounts; access only to personnel who actually handle privacy/support.
- Gmail administrator auto-delete = 365 days, permanent deletion after the period. Extract any legally required complaint/dispute facts into the legal-retention store rather than keeping whole email threads for years. [V16]
- No Vault/legal hold by default. Use only for a documented legal requirement.
- Review subprocessor list at setup and on vendor-change review. [V18]

8. Remaining non-policy facts

No new strategic decision is required to continue. The following are verification tasks before publication:

- Hosting.kr exact AWS region is optional verification rather than a publication blocker. If later account/server-IP evidence contradicts the domestic-hosting assumption, revise the processor/transfer classification promptly.
- If Whop later makes the standalone Seller Data Sharing Addendum available, archive/review it. Current Seller Terms incorporation plus Whop Privacy Policy are sufficient for the conservative final classification used here.
- Record actual Render workspace plan for exact internal log/PITR windows.
- After Google Workspace setup, capture evidence of the chosen configuration.
- Insert final operator/CPO/address/business-registration placeholders.
- Perform final law check on launch-date versions, particularly if launch is on or after September 11, 2026.

Source register

[L1] **Korea Personal Information Protection Act (PIPA), current text.** <https://law.go.kr/LSW/lsInfoP.do?lsiSeq=270351>

[L2] **PIPA Article 28-8 - overseas transfers.** <https://www.law.go.kr/LSW/lsLinkCommonInfo.do?chrClsCd=010202&lsJoLnkSeq=1029334737>

[L3] **PIPC Privacy Policy Writing Guidelines, April 2026.** <https://www.pipc.go.kr/np/cop/bbs/selectBoardArticle.do?bbsId=BS217&mCode=D010030000.Updated&nttlD=12018>

[L4] **Korean E-Commerce Act Articles 17-18 - withdrawal and refunds.** <https://law.go.kr/LSW/lsLinkCommonInfo.do?chrClsCd=010202&lsJoLnkSeq=1013449821>

[L5] **Korean E-Commerce Act Enforcement Decree Article 6 - transaction-record retention.** <https://www.law.go.kr/LSW/lsInfoP.do?lsiSeq=288143>

[L6] **Korean Civil Act Articles 4-5 - majority and minors.** <https://www.law.go.kr/LSW/lsInfoP.do?lsiSeq=284415>

[L7] **Korea AI Basic Act Article 31 - generative-AI transparency.** <https://www.law.go.kr/LSW/lsLinkCommonInfo.do?lsJoLnkSeq=1031809549>

[L8] **Korea AI Basic Act Enforcement Decree Article 23 - disclosure/marketing methods.** <https://www.law.go.kr/lsLinkCommonInfo.do?lspttninfSeq=198075>

[L9] **PIPA Enforcement Decree Articles 39-40 - 72-hour breach notice/reporting.** <https://www.law.go.kr/LSW/lsLawLinkInfo.do?chrClsCd=010202&lsJoLnkSeq=1000089686>

[V1] **xAI API Security FAQ - Zero Data Retention.** <https://docs.x.ai/developers/faq/security>

[V2] **xAI Enterprise Terms.** <https://x.ai/legal/terms-of-service-enterprise>

[V3] **xAI DPA.** <https://x.ai/legal/data-processing-addendum>

[V4] **xAI Subprocessor List.** <https://x.ai/legal/subprocessor-list>

[V5] **Render Regions.** <https://render.com/docs/regions>

[V6] **Render Logs.** <https://render.com/docs/logging>

[V7] **Render Postgres Recovery and Backups.** <https://render.com/docs/postgresql-backups>

[V8] **Clerk DPA.** <https://clerk.com/legal/dpa>

[V9] **Clerk deleteUser API.** <https://clerk.com/docs/reference/backend/user/delete-user>

[V10] **Whop Seller Terms - incorporates Seller Data Sharing Addendum.** <https://whop.com/seller-terms/>

[V11] **Whop legal-document upload and acceptance controls.**
<https://docs.whop.com/manage-your-business/manage-business/legal-documents>

[V12] **Whop Payment API.** <https://docs.whop.com/api-reference/payments/retrieve-payment>

[V13] **Whop Membership API.** <https://docs.whop.com/api-reference/memberships/retrieve-membership>

[V14] **Whop Privacy Policy.** <https://whop.com/privacy/>

[V15] **Google Workspace Data Regions.** <https://support.google.com/a/answer/14310028>

[V16] **Google Workspace Gmail Auto-Delete.** <https://support.google.com/a/answer/151128>

[V17] **Google Workspace 2-Step Verification.** <https://support.google.com/a/answer/175197>

[V18] **Google Workspace Subprocessors.** <https://workspace.google.com/terms/subprocessors/>

[V19] **Hosting.kr / Megazone Privacy Policy.** <https://www.hosting.kr/policies/privacy>

[V20] **Hosting.kr Linux webhosting - AWS-based hosting environment.** <https://www.hosting.kr/webhosting>

[V21] **Hosting.kr Raw Access log controls.** <https://help.hosting.kr/hc/ko/articles/900005240146>

[V22] **Hosting.kr Metrics Editor - Webalizer / Analog / AWStats controls.**
<https://help.hosting.kr/hc/ko/articles/900006193483>

[V23] **Hosting.kr cancellation / deletion and long-backup behavior.**
<https://help.hosting.kr/hc/ko/articles/4408216133529>

[V24] **Whop Seller Data Sharing Addendum - incorporated by reference in Seller Terms; public Seller Terms provide the controlling incorporation point.** <https://whop.com/seller-terms/>